

SCAN REPORT

CRITICAL SEVERITY

https://demo.testfire.net

generated 2026-09-18 14:54:03 · htool v3.2.0 · authorised security assessment · by Resolute Femi

Overall severity: **CRITICAL** - 6 security findings · 4 open ports · automated authorised scan.

4 OPEN PORTS	1 SQL INJECTION	2 XSS
1 TAKEOVERS	0 ZONE TRANSFERS	2 CVE MATCHES
5 PATHS FOUND	2 SUBDOMAINS	4 TECHNOLOGIES

Open Ports (4)

- 80 - HTTP
- 443 - HTTPS
- 22 - SSH
- 3306 - MySQL

SQL Injection (1)

- https://demo.testfire.net/search?q=1' OR '1'='1

Cross-Site Scripting (XSS) (2)

- https://demo.testfire.net/comment?msg=<script>alert(1)</script>
- https://demo.testfire.net/profile?name=

Subdomain Takeovers (1)

- dev.demo.testfire.net - dangling CNAME -> ghost.io

Known CVE Matches (2)

- CVE-2021-44228 - Apache Log4j2 JNDI lookup RCE (CVSS 10.0)
- CVE-2018-11776 - Apache Struts2 RCE (CVSS 9.8)

Discovered Paths (5)

- /admin
- /backup.zip
- /.env
- /phpmyadmin
- /robots.txt

Subdomains (2)

- mail.demo.testfire.net
- dev.demo.testfire.net

Detected Technologies (4)

- nginx/1.18.0
- PHP/7.4.3
- jQuery 2.1.1
- [WAF] none detected

SSL / TLS

issuer: Self-signed certificate
cipher: TLS_AES_256_GCM_SHA384
protocol: TLSv1.3
expires: 2027-01-01
grade: B

Security Headers

Missing: Strict-Transport-Security
Missing: Content-Security-Policy
Missing: X-Frame-Options
Present: X-Content-Type-Options

Scan Errors (1)

- timeout reaching :8080

Recommendations (8)

1. Use parameterised queries / prepared statements for every database call and validate all user input server-side.
2. Escape HTML output, sanitise user-supplied content and deploy a strict Content-Security-Policy header.
3. Remove dangling DNS CNAME records and reclaim or delete the vulnerable subdomains immediately.
4. Upgrade the matched software components to the latest vendor-supported releases to clear known CVEs.
5. Add missing HTTP security headers: HSTS, Content-Security-Policy, X-Frame-Options and X-Content-Type-Options.
6. Review all open ports and close or firewall any service that is not required for business operation.
7. Remove or protect exposed admin panels, backups and config files discovered in the path scan.
8. Re-run htool after remediation and keep the HTML/JSON/PDF reports for compliance tracking.